Natalyx MVP Fixes

Work Package 00: Preservation, cloud diagnosis, and PR reconciliation

L. Rhodes (plan owner) - A. Zhao (technical feedback reconciled)

2026-07-12

Contents

1 Work Package 00: Preservation, cloud diagnosis, and PR reconciliation 2

1.1 Purpose and outcome . . . 2
1.2 Verified current-state evidence . . . 3
1.3 Architecture and contracts . . . 3
1.4 Explicit PR sequence . . . 24
1.5 Cross-repository coordination . . . 27
1.6 Test and acceptance matrix . . . 27
1.7 Risks and decisions . . . 28
1.8 Existing-work salvage . . . 29
1.9 Ownership recommendation . . . 30
1.10 Definition of done . . . 30

1 Work Package 00: Preservation, cloud diagnosis, and PR reconciliation

Review draft only. Ownership and sequencing remain recommendations until Luke and Alan approve the plan together.

Plan	Value
Work package	WP00
Plan file	`WP00 - Preservation, cloud diagnosis, and PR reconciliation.md`
Proposed PRs	P00-01
Inspection snapshot	2026-07-12 19:30 America/New_York

1.1 Purpose and outcome

Problem. The live app is returning ALB 503 responses while overlapping draft PRs and protected dirty worktrees contain useful but contradictory implementations.

Why this package exists. It creates a reviewable boundary so the programme can progress without mixing product, data, security, infrastructure and rollout concerns in one oversized change.

Completed outcome. A source-of-truth baseline with Alan's completed review independently dispositioned, existing work mapped, and explicit no-delete/no-close conditions before replacement work begins.

Explicit non-goals.

- No code porting

- No PR closure or retargeting
- No branch/worktree cleanup
- No deployment or AWS mutation

1.2 Verified current-state evidence

Classification is explicit: **verified** is observed code/PR/live behavior; **verified limitation** records an evidence gap; **design authority** is an approved planning source; **design decision** is proposed future behavior. None is silently treated as another.

ID	Class	Repository / ref	File, construct or location	Finding
E-001	verified	live dev / 2026-07-12 19:30 America/New_York	https://dev.app.natalyx.health/ and /health	Both requests returned HTTP 503 from awselb/2.0; the deployed participant app is not presently usable.
E-002	verified limitation	AWS dev / 2026-07-12 19:30 America/New_York	aws sts get-caller-identity –profile natalyx-dev	Local AWS SSO was expired, so current ECS desired/running counts and task revision were not independently verified. Gate A0 must refresh access and capture them.
E-003	verified	GitHub / 2026-07-12 19:30 America/New_York	NatalyxPlatform open PR query	App PRs #112, #117, #119, #121, #122, #123 and #124 and design-system PRs #7/#8 are open; all app PRs are drafts.
E-028	verified review	app / PR #124 comment 4948149089	Consolidated review - findings for the WP00 extraction ledger	Alan's completed review classifies #124 as high-value extraction material rather than a merge unit and identifies transaction, privacy, scoring, access, validation, invariant, exposure, retention, performance, CSS and CI findings.
E-029	verified preserved branch	app / feat/byos-journey-wave-2@5b63e3a7	exact three-commit stack on e853821	Wave 2 contains phase-1 cluster pages, metadata-only request/review, case anchoring and role/owner fixes. Controlled local evidence passed 535 tests with 9 skipped and 36/36 focused tests, but no branch checks, PostgreSQL, browser/accessibility or visual run exists.

1.3 Architecture and contracts

- Treat every existing branch and worktree as read-only evidence until its valuable files, tests, and reviewer findings have a named destination.
- Use Drive as the canonical review surface; the locally validated Project catalogue remains benched until separately reactivated and synced.

- Do not infer live health from GitHub build success; Gate A0 requires a known revision and live evidence.

Contract area	Package rule
Ownership boundary	`.github`; repository-specific PRs remain separate.
Entities/state	No new runtime entity; evidence/coordination only.
Authorization	Authenticated subject/service plus entity membership, role, purpose, consent and expected revision; query parameters, links and UI state are never authority.
API/service	No broad public contract; use the focused commands/events in each PR.
Storage	No new storage; preserve current state read-only for this package.
Audit	Use the common transition envelope and append-only source/event identifiers; redact tokens, raw documents, prompts and sensitive payloads.
Failure	Fail closed for authorization, provenance, money, document and PHI boundaries; expose a bounded actionable error and preserve retry/repair evidence.
Observability	Correlation, policy/schema/config version, transition and dependency result metrics without PHI/PII payload logging.
Compatibility	Additive/dual-compatible changes, explicit version pins, old/new revision window and named forward repair.
Privacy/PHI	Synthetic only through A2; approved PII only at B1; PHI remains blocked until formal B2.

1.3.1 Frozen independent recommendation matrix

This matrix was completed from read-only repository/Drive evidence before any canonical planning source was edited.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-01	Treat PR #124 as WP00 extraction material, not a merge/conflict-resolution unit.	Accept	No independently mergeable unit survives the stale base and domain blockers. Preserve concepts/tests through clean replacement work.	WP00; P03-02/03; P04-01/02/03; P05-02/03; P06-02/03; P09-04; P10-02; P11-03/04; P12-02	No - disposition resolved; closure/deletion still requires later team confirmation.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-02	Use corrected PR #122 as the invitation/case-shell baseline.	Accept with modification	#122 is authoritative for named tested behavior and reusable tests, not for final entities, runtime DDL, generic fact/proposal authority or the whole journey model.	WP01; WP02; WP03; WP09; WP10; WP11; WP12	No.
REC-03	Node 0 must delegate invitations to shared authority and make issuance/redemption transactionally complete.	Accept with modification	One invitation authority serves separate resource targets and lifecycles; optional profile completion is resumable rather than forced into membership redemption.	WP03 P03-02/03; WP06 P06-02; A1/A2	No; D-AUTH-02 remains for Cognito admission mechanics.
REC-04	Resolve canonical identity, participation, access and authorization before schema encoding.	Accept with modification	Identity binds principal to person; participation records domain relationship; grants carry resource capabilities; authorization uses verified context, ownership and purpose. Lens is presentation only.	P03-02/03/05; P04-01/02; P09-04; P13-05; A1/B1	Resolved as D-AUTH-03.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-05	Restrict IP-entered pre-join GC information and remove unverified suitability ranking/gating.	Accept with modification	Allow minimum-necessary relationship/outreach/logistics context only. Health, mental health, substances, citizenship, race, pregnancy, insurance and eligibility normally wait for authenticated GC entry; no provisional value drives critical decisions.	WP04; WP05 P05-02; WP06; WP10; A1/A2	Resolved as D-DATA-03; exact cross-role fields remain D-DATA-01.
REC-06	Correct shared-memory private notes and migrate already-written rows.	Accept with modification	Run a metadata-only inventory first; record zero-row evidence if none. If rows exist, deny shared/Ask reads immediately and migrate narrowly without broadening access.	WP04 P04-02; WP10 P10-02; A1/A2	No; actual affected-row count is execution evidence, not an architecture choice.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-07	Preserve Wave 2 work from 5b63e3a rather than reimplementing useful behavior.	Accept with modification	Treat 5b63e3a as the strongest cumulative evidence source, not an implementation baseline. Reuse tests and semantics only after the named contract changes.	WP00; WP03; WP09; WP11; WP12; WP13; A2/B1	No.
REC-08	Separate metadata-only document requests from the full content pipeline.	Accept with modification	A request/readiness marker is not a document. Content state and review begin only after a version exists, and partial merges fail closed.	WP09 P09-01/03/04/05/06; P12-02; A2	D-DOC-01/02 and D-PHI-01 remain open for content.
REC-09	Move foundational RLS and non-owner runtime before real-user PII.	Accept	App-only checks are inadequate for real-user PII given current broad readers. No alternative isolation model has equivalent evidence at lower programme cost.	WP13 P13-05/06/07; B1/B2	D-PHI-01/02 remain for approved scope/controls/approvers, not for whether RLS precedes B1.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-10	Make #122 Python CI required, stable and resistant to bypass.	Defer	Accept the workflow recommendation now, but enforcement choice/evidence is unavailable. Until D-CI-01 resolves, do not call it bypass-resistant or open real-user gates.	WP01 P01-01; A0 and every later app PR	Yes - D-CI-01, owner Luke; options and required read-back/negative test are recorded.
REC-11	Add an explicit Node 0 IP-owner guard and correct non-IP behavior.	Accept with modification	Use one subject-derived capability policy across commands and pages; return explicit deny/role destination without creating a case.	WP03 P03-05; WP05 P05-03; A1	No.
REC-12	Bound and type Node 0 inputs and malformed request behavior.	Accept	Use strict enums/max lengths plus body/collection limits and controlled 4xx errors; do not silently truncate.	WP05; WP06; WP09; WP12	No; exact numerical limits are PR acceptance details and D-DOC-02 for files.
REC-13	Move candidate and invitation invariants from app checks into PostgreSQL migrations.	Accept	Business invariants that can be represented in PostgreSQL must remain true independently of application races.	WP02; WP03; WP04; WP05; A1	No.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-14	Replace broad public/cloud prefixes with explicit exposure.	Accept	Explicit route identity is the simplest fail-closed control for the current app.	WP03; WP05; WP06; WP09; WP13; A1/A2	No.
REC-15	Project expiry on GET and add token/PDF cache, referrer and indexing protections.	Accept	Read projection and mutation must agree, and sensitive responses must be non-cacheable with restrictive referrer/noindex policy.	WP03; WP05	No.
REC-16	Bound candidate/invitation and memory queries and remove N+1 behavior.	Accept	Filter/limit at the authoritative storage boundary rather than after loading broad rows.	WP05; WP09; WP10; WP12	No.
REC-17	Add candidate retention, archive, correction and deletion behavior.	Accept	Implement the lifecycle in the candidate domain; keep the exact duration as the named bounded privacy decision.	WP04; WP05 P05-02; A1	Yes - D-DATA-02 supplies duration and exception policy before live use.
REC-18	Move #124's large global CSS addition to route-scoped Node 0 styling.	Accept with modification	Port only necessary styles through route scope and released DS contracts; block on interaction/accessibility/security, not cosmetic literal purity.	WP05; WP11; WP12	No.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-19	Retain unaddressed claim semantics and one-time share-link rotation.	Accept with modification	Retain token mechanics and low-risk semantics only for a pending free-workspace claim; never layer bearer access onto a paid case.	WP03 P03-02/03; WP06	Resolved by D-AUTH-01.
REC-20	Standardize organization handling on NATALYX_ORG_ID.	Reject	Configuration unification is convenient evidence, not the final authorization model. Organization must be verified from the authenticated/granted resource context.	WP03 P03-05; WP13 P13-05	No.
REC-21	Land the GC at shared /case/home and remove a duplicate GC Node 0 home.	Accept with modification	Keep one shared participant shell pattern, but route by actual resource: free-workspace GC projection before promotion, case home only after paid-case access exists.	WP03; WP06; WP09; WP12	No.

ID	Recommendation	Disposition	Rationale	Affected WPs / PRs / gates	Decision
REC-22	Keep return_to, token-scoped landing, duplicate-home cleanup, symbol cleanup and refreshed DS assets from #124.	Accept with modification	Adopt the behavior and cleanup, but keep redirect validation, resource-specific landing and canonical DS release ownership.	WP03; WP05; WP11; WP12	No.

1.3.2 Assessment detail

1.3.2.1 REC-01 - Accept

Assessment field	Recorded conclusion
Recommendation	Treat PR #124 as WP00 extraction material, not a merge/conflict-resolution unit.
Supporting evidence	Alan comment 4948149089; #124@84a5a84; merge-tree against #122@e853821 produced about 93 conflict regions across 11 files.
Prior plan treatment	Already warned against merge but left final disposition pending.
Assumptions	Corrected #122 and replacement PRs remain available as source history.
Security, privacy and operational impact	Avoids stale invitation/security behavior and case-shaped Node 0 reaching users; preserves useful tests/copy/assets.
Dependency and migration impact	WP00 ledger; P03/P04/P05/P06/P09/P10/P11/P12 destinations; no branch mutation.
Alternatives considered	Merge whole branch; cherry-pick mixed commits; file-level extraction.
Rationale	No independently mergeable unit survives the stale base and domain blockers. Preserve concepts/tests through clean replacement work.
Affected WPs / PRs / gates	WP00; P03-02/03; P04-01/02/03; P05-02/03; P06-02/03; P09-04; P10-02; P11-03/04; P12-02
Explicit decision required	No - disposition resolved; closure/deletion still requires later team confirmation.

1.3.2.2 REC-02 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Use corrected PR #122 as the invitation/case-shell baseline.
Supporting evidence	e853821; 499-test report and green workflow; verified return_to, TTL ceiling, CAS, self/existing-member refusal, one-live-GC invariant, transactional join, paired lenses and fail-closed Learn.
Prior plan treatment	Selective salvage, pending reconciliation.
Assumptions	Behavioral tests can be ported without retaining startup DDL or the case-only domain model.
Security, privacy and operational impact	Retains proven concurrency/auth safety while preventing weak participation/provenance/schema semantics becoming programme authority.
Dependency and migration impact	P01-01, P03-01/03/05, P09-04, P11-03/04, P12-02; re-express schema through WP02.
Alternatives considered	Treat all #122 code/schema as canonical; discard it; behavior/test baseline only.
Rationale	#122 is authoritative for named tested behavior and reusable tests, not for final entities, runtime DDL, generic fact/proposal authority or the whole journey model.
Affected WPs / PRs / gates	WP01; WP02; WP03; WP09; WP10; WP11; WP12
Explicit decision required	No.

1.3.2.3 REC-03 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Node 0 must delegate invitations to shared authority and make issuance/redemption transactionally complete.
Supporting evidence	#124 splits supersede/create/link/timeline and redemption/profile facts across commits; corrected #122 supplies CAS/TTL guards.
Prior plan treatment	Separate workspace claim and paid-case invitation but transaction boundary was underspecified.
Assumptions	Identity-provider interaction may require an idempotent completion workflow around a database transaction/outbox.
Security, privacy and operational impact	Prevents valid orphan tokens, partial membership/onboarding and possession-only case access.
Dependency and migration impact	P03-02 atomically binds workspace claim/identity/consent; P03-03 atomically redeems invite/participation/access/consent/audit; P06-02 resumes optional onboarding idempotently.
Alternatives considered	One huge cross-system transaction; explicit idempotent saga/outbox; current sequential commits.

Assessment field	Recorded conclusion
Rationale	One invitation authority serves separate resource targets and lifecycles; optional profile completion is resumable rather than forced into membership redemption.
Affected WPs / PRs / gates	WP03 P03-02/03; WP06 P06-02; A1/A2
Explicit decision required	No; D-AUTH-02 remains for Cognito admission mechanics.

1.3.2.4 REC-04 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Resolve canonical identity, participation, access and authorization before schema encoding.
Supporting evidence	#122/Wave 2 account_memberships roles double as party role, lens and authorization; first-active membership selection; no party/person alignment; callers pass viewer role/lens; RLS absent.
Prior plan treatment	Roles, membership and projections were present but their ownership was not explicit.
Assumptions	A principal can be staff globally without participant-data access and a person can participate without an active grant.
Security, privacy and operational impact	Eliminates confused role authority and gives application/RLS one auditable policy input.
Dependency and migration impact	P03-05 adds identity binding, participation and access-grant constraints; later domain migrations and P13-05 consume the contract.
Alternatives considered	Single membership table/role enum; participation-only authorization; separate grants/capabilities.
Rationale	Identity binds principal to person; participation records domain relationship; grants carry resource capabilities; authorization uses verified context, ownership and purpose. Lens is presentation only.
Affected WPs / PRs / gates	P03-02/03/05; P04-01/02; P09-04; P13-05; A1/B1
Explicit decision required	Resolved as D-AUTH-03.

1.3.2.5 REC-05 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Restrict IP-entered pre-join GC information and remove unverified suitability ranking/gating.
Supporting evidence	#124 scores mental health, substance, citizenship, pregnancy and support claims into 0-100/high_viability/critical_flag and sorts/gates guidance.

Assessment field	Recorded conclusion
Prior plan treatment	Provisional attribution existed but still allowed a preliminary hard-criteria check.
Assumptions	Before GC joins, the legitimate purpose is low-pressure outreach preparation, not eligibility or professional assessment.
Security, privacy and operational impact	Reduces sensitive third-party processing, discrimination and false clinical/eligibility authority.
Dependency and migration impact	P04-02 provenance; P05-02 strict allowlist; P06-02 GC-authored data; P10 scopes; legacy scores retained only as source-labelled evidence or excluded.
Alternatives considered	Keep ranking with disclaimer; professional approval later; neutral questions only.
Rationale	Allow minimum-necessary relationship/outreach/logistics context only. Health, mental health, substances, citizenship, race, pregnancy, insurance and eligibility normally wait for authenticated GC entry; no provisional value drives critical decisions.
Affected WPs / PRs / gates	WP04; WP05 P05-02; WP06; WP10; A1/A2
Explicit decision required	Resolved as D-DATA-03; exact cross-role fields remain D-DATA-01.

1.3.2.6 REC-06 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Correct shared-memory private notes and migrate already-written rows.
Supporting evidence	#124 saves Conversation Guide notes with scope=shared and Ask loads shared memory; local inspected SQLite had zero affected rows; #124 was not deployed; remote database state was not verified.
Prior plan treatment	New private/shared ledger planned; explicit legacy remediation was missing.
Assumptions	Source kind identifies guide notes and owner can normally be recovered from subject/person provenance.
Security, privacy and operational impact	Prevents IP reflection notes reaching GC/provider/intelligence while preserving audit and avoiding content in logs.
Dependency and migration impact	P04-02 person-owned contract; P10-02 inventory, immediate exclusion, idempotent private/quarantine migration; ambiguous owner quarantines.
Alternatives considered	Behavior-only fix; delete rows; owner-safe migration/quarantine.

Assessment field	Recorded conclusion
Rationale	Run a metadata-only inventory first; record zero-row evidence if none. If rows exist, deny shared/Ask reads immediately and migrate narrowly without broadening access.
Affected WPs / PRs / gates	WP04 P04-02; WP10 P10-02; A1/A2
Explicit decision required	No; actual affected-row count is execution evidence, not an architecture choice.

1.3.2.7 REC-07 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Preserve Wave 2 work from 5b63e3a rather than reimplementing useful behavior.
Supporting evidence	Exact three-commit stack on e853821; 535 passed/9 skipped and 36 focused tests; two independent defects reproduced; runtime DDL, caller roles, broad loaders and no RLS remain.
Prior plan treatment	Wave 2 was previously missing and blocked final mapping.
Assumptions	The branch remains paused and available for later extraction.
Security, privacy and operational impact	Saves tested presentation/transaction semantics without importing restart loss, stale approval, metadata/content conflation or weak access.
Dependency and migration impact	P03-05, P09-01/04/06, P11-03/04, P12-02, P13-05; schema re-expressed as migrations.
Alternatives considered	Direct merge/cherry-pick; discard; selective adaptation/test port.
Rationale	Treat 5b63e3a as the strongest cumulative evidence source, not an implementation baseline. Reuse tests and semantics only after the named contract changes.
Affected WPs / PRs / gates	WP00; WP03; WP09; WP11; WP12; WP13; A2/B1
Explicit decision required	No.

1.3.2.8 REC-08 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Separate metadata-only document requests from the full content pipeline.
Supporting evidence	Wave 2 creates an approvable documents row with storage_uri empty; request labels may contain sensitive data; P09 baseline coupled active-case UI to full upload pipeline.

Assessment field	Recorded conclusion
Prior plan treatment	P09-04 depended on P09-03 and mixed progress/documents; no independent requirement/work-item model.
Assumptions	Phase-1 readiness coordination can operate synthetically without receiving file bytes.
Security, privacy and operational impact	Avoids false artifact approval and permits safe partial delivery while content remains quarantined/disabled.
Dependency and migration impact	P09-01 defines both machines; P09-04 owns metadata requirements/work items and phase-1 surfaces without P09-03; P09-06 integrates content versions after P09-03; P09-05 depends P09-06.
Alternatives considered	Single documents table; metadata-only workflow first; full pipeline first.
Rationale	A request/readiness marker is not a document. Content state and review begin only after a version exists, and partial merges fail closed.
Affected WPs / PRs / gates	WP09 P09-01/03/04/05/06; P12-02; A2
Explicit decision required	D-DOC-01/02 and D-PHI-01 remain open for content.

1.3.2.9 REC-09 - Accept

Assessment field	Recorded conclusion
Recommendation	Move foundational RLS and non-owner runtime before real-user PII.
Supporting evidence	Runtime uses owner-level startup DDL; app/Wave 2 storage has broad/global loaders; no DB policy enforcement or pool-context proof.
Prior plan treatment	P13-05 was a B2 prerequisite only.
Assumptions	Synthetic A1/A2 may validate features before B1, but no real subject data is admitted.
Security, privacy and operational impact	Database denies cross-org/resource/owner access if an app guard fails; reduces B1 breach blast radius.
Dependency and migration impact	P13-05/06/07 move to B1; FORCE RLS, NOBYPASSRLS runtime, transaction-local verified context and pool reset tests; B2 remains separate evidence approval.
Alternatives considered	App-only isolation; separate databases per cohort; RLS at B2.
Rationale	App-only checks are inadequate for real-user PII given current broad readers. No alternative isolation model has equivalent evidence at lower programme cost.
Affected WPs / PRs / gates	WP13 P13-05/06/07; B1/B2
Explicit decision required	D-PHI-01/02 remain for approved scope/controls/approvers, not for whether RLS precedes B1.

1.3.2.10 REC-10 - Defer

Assessment field	Recorded conclusion
Recommendation	Make #122 Python CI required, stable and resistant to bypass.
Supporting evidence	#122 workflow passed; #124 ran only build/contract checks; main lacks Python/PostgreSQL CI; private-repo protection/ruleset API returned plan-level 403.
Prior plan treatment	P01-01 added tests but did not define stable contexts, workflow hardening or enforcement limitation.
Assumptions	Repository billing/visibility may change independently of code.
Security, privacy and operational impact	Prevents test-path bypass and false governance claims; adds PostgreSQL evidence.
Dependency and migration impact	P01-01: no path filters, stable names, pinned action SHAs, supported runtime, constraints, timeouts, PostgreSQL job; D-CI-01 governs repository enforcement/readback.
Alternatives considered	Procedural review only; GitHub plan/ruleset upgrade; externally enforced merge queue.
Rationale	Accept the workflow recommendation now, but enforcement choice/evidence is unavailable. Until D-CI-01 resolves, do not call it bypass-resistant or open real-user gates.
Affected WPs / PRs / gates	WP01 P01-01; A0 and every later app PR
Explicit decision required	Yes - D-CI-01, owner Luke; options and required readback/negative test are recorded.

1.3.2.11 REC-11 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Add an explicit Node 0 IP-owner guard and correct non-IP behavior.
Supporting evidence	#124 ensure endpoint lets any authenticated subject mint a primary-IP case; viewer/provider/staff paths can fall into storage errors/500.
Prior plan treatment	General workspace authorization existed without a shared participant/API guard acceptance matrix.
Assumptions	Staff tools are separate from participant Node 0 routes.
Security, privacy and operational impact	Prevents privilege creation, role confusion and avoidable errors.
Dependency and migration impact	P03-05 subject-derived capabilities; P05-03 shared IP-owner guard and negative role tests.
Alternatives considered	Per-route checks; shared router dependency/service policy; redirect all roles.

Assessment field	Recorded conclusion
Rationale	Use one subject-derived capability policy across commands and pages; return explicit deny/role destination without creating a case.
Affected WPs / PRs / gates	WP03 P03-05; WP05 P05-03; A1
Explicit decision required	No.

1.3.2.12 REC-12 - Accept

Assessment field	Recorded conclusion
Recommendation	Bound and type Node 0 inputs and malformed request behavior.
Supporting evidence	#124 hand-parses unbounded names/notes/questions/JSON/forms/collections/PDF content; Wave 2 silently truncates labels/notes.
Prior plan treatment	Validation was implicit and spread across feature PRs.
Assumptions	Limits can be product-specific but must reject rather than silently alter user data.
Security, privacy and operational impact	Controls denial-of-service, log/storage amplification and ambiguous stored content.
Dependency and migration impact	P05-02 typed candidate commands/collections; P05-03 form/PDF/body limits; P06-02 onboarding; P09-04 structured metadata/reviewer note; P12-01 Ask.
Alternatives considered	Global proxy limit only; silent slicing; layered strict validation.
Rationale	Use strict enums/max lengths plus body/collection limits and controlled 4xx errors; do not silently truncate.
Affected WPs / PRs / gates	WP05; WP06; WP09; WP12
Explicit decision required	No; exact numerical limits are PR acceptance details and D-DOC-02 for files.

1.3.2.13 REC-13 - Accept

Assessment field	Recorded conclusion
Recommendation	Move candidate and invitation invariants from app checks into PostgreSQL migrations.
Supporting evidence	#124 lacks candidate-case FK, invitation-link uniqueness, one-active-outreach constraint and checks for enums/scores; concurrent writes can violate product rules.
Prior plan treatment	WP04/WP05 proposed new schema but did not enumerate all reviewed invariants.
Assumptions	Versioned migrations and expand/contract compatibility precede domain tables.

Assessment field	Recorded conclusion
Security, privacy and operational impact	Prevents orphan/duplicate/contradictory state under concurrency.
Dependency and migration impact	P04-01 FKs/uniqueness; P05-02 outreach constraints and no score bounds because ranking is removed; P03-02/03 claim/invite uniqueness; P02-03 migrations.
Alternatives considered	App locks only; advisory locks; database constraints plus commands.
Rationale	Business invariants that can be represented in PostgreSQL must remain true independently of application races.
Affected WPs / PRs / gates	WP02; WP03; WP04; WP05; A1
Explicit decision required	No.

1.3.2.14 REC-14 - Accept

Assessment field	Recorded conclusion
Recommendation	Replace broad public/cloud prefixes with explicit exposure.
Supporting evidence	#124 exposes /node0/onboarding/ publicly and /api/node0/ by prefix; Wave 2 demonstrates exact phase-1 allowlisting.
Prior plan treatment	Fail-closed route policy existed but did not assign this finding.
Assumptions	New routes require explicit security review before cloud/public reachability.
Security, privacy and operational impact	Prevents future routes inheriting token/public or cloud exposure accidentally.
Dependency and migration impact	P03-02, P05-03, P06-02 exact registries/dependencies; P09-04 exact cluster paths; P13-03 route-negative inventory.
Alternatives considered	Prefix allowlist; per-route registry; separate public app.
Rationale	Explicit route identity is the simplest fail-closed control for the current app.
Affected WPs / PRs / gates	WP03; WP05; WP06; WP09; WP13; A1/A2
Explicit decision required	No.

1.3.2.15 REC-15 - Accept

Assessment field	Recorded conclusion
Recommendation	Project expiry on GET and add token/PDF cache, referrer and indexing protections.
Supporting evidence	#124 expired links look active until POST; token-bearing pages/PDFs lack no-store and restrictive referrer policy.

Assessment field	Recorded conclusion
Prior plan treatment	Token transitions were covered, response exposure was not.
Assumptions	Tokens remain URL-borne only where unavoidable and never appear in telemetry.
Security, privacy and operational impact	Reduces stale-action confusion and token/sensitive-output leakage via browser cache, referrer or indexing.
Dependency and migration impact	P03-02/03 GET+command expiry and response headers; P05-03 outreach PDF headers; security tests.
Alternatives considered	POST-only check; session exchange; header hardening plus one-time token.
Rationale	Read projection and mutation must agree, and sensitive responses must be non-cacheable with restrictive referrer/noindex policy.
Affected WPs / PRs / gates	WP03; WP05
Explicit decision required	No.

1.3.2.16 REC-16 - Accept

Assessment field	Recorded conclusion
Recommendation	Bound candidate/invitation and memory queries and remove N+1 behavior.
Supporting evidence	#124 looks up invitations per candidate and loads all shared memory before Python filtering; Wave 2 removes one reviewer-inbox N+1 but retains broad loaders.
Prior plan treatment	Performance was a general risk rather than explicit acceptance criteria.
Assumptions	Pagination and purpose-scoped limits are compatible with Node 0 and Ask UX.
Security, privacy and operational impact	Bounds latency/memory, narrows accidental data access and improves tenant isolation.
Dependency and migration impact	P05-02 batched query-shaped hydration/indexes; P10-02 scope/subject limits at persistence; P12-01 bounded context; P09-04 owner-scoped query shapes.
Alternatives considered	Cache current readers; batch only; purpose-scoped SQL.
Rationale	Filter/limit at the authoritative storage boundary rather than after loading broad rows.
Affected WPs / PRs / gates	WP05; WP09; WP10; WP12
Explicit decision required	No.

1.3.2.17 REC-17 - Accept

Assessment field	Recorded conclusion
Recommendation	Add candidate retention, archive, correction and deletion behavior.
Supporting evidence	#124 stores sensitive third-party assessments without a lifecycle; current plan has D-DATA-02 but implementation mapping was weak.
Prior plan treatment	Retention decision and legacy backfill existed.
Assumptions	Legal/privacy may set the exact period; source/audit may require tombstones rather than raw-content retention.
Security, privacy and operational impact	Reduces unnecessary third-party data retention while preserving correction/audit needs.
Dependency and migration impact	D-DATA-02; P04-02/03 provenance/tombstones; P05-02 archive/anonymize/delete command/job and evidence.
Alternatives considered	Indefinite retention; immediate deletion; shortest justified period with tombstone/audit.
Rationale	Implement the lifecycle in the candidate domain; keep the exact duration as the named bounded privacy decision.
Affected WPs / PRs / gates	WP04; WP05 P05-02; A1
Explicit decision required	Yes - D-DATA-02 supplies duration and exception policy before live use.

1.3.2.18 REC-18 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Move #124's large global CSS addition to route-scoped Node 0 styling.
Supporting evidence	About 3,030 lines were added to global style.css; participant DS and route-specific recipes exist.
Prior plan treatment	P05-03 and P11-03 mentioned DS adoption but not the global-style finding.
Assumptions	Participant and internal/operator design systems remain separate.
Security, privacy and operational impact	Limits cross-surface regressions and clarifies style ownership without making aesthetic purity a release gate.
Dependency and migration impact	P05-03 node0.css; P11-03 released tokens/recipes; P12-02 visual/a11y verification.
Alternatives considered	Keep global block; CSS modules/build; route stylesheet plus shared DS.
Rationale	Port only necessary styles through route scope and released DS contracts; block on interaction/accessibility/security, not cosmetic literal purity.
Affected WPs / PRs / gates	WP05; WP11; WP12
Explicit decision required	No.

1.3.2.19 REC-19 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Retain unaddressed claim semantics and one-time share-link rotation.
Supporting evidence	#124 gates allow_unaddressed to GC intent, stores hash only, rotates/supersedes, and displays plaintext once; corrected #122 supplies case-invite guards.
Prior plan treatment	Workspace claim separated conceptually but shared engine/resource-target distinction was incomplete.
Assumptions	Bearer possession cannot reveal sensitive data or create paid-case membership.
Security, privacy and operational impact	Keeps low-friction outreach while bounding replay, forwarding and privilege escalation.
Dependency and migration impact	P03-02 workspace claim target; P03-03 recipient-bound case target; shared token/CAS primitives, distinct state machines and consent.
Alternatives considered	Addressed links only; unaddressed case invite; unaddressed low-risk workspace claim.
Rationale	Retain token mechanics and low-risk semantics only for a pending free-workspace claim; never layer bearer access onto a paid case.
Affected WPs / PRs / gates	WP03 P03-02/03; WP06
Explicit decision required	Resolved by D-AUTH-01.

1.3.2.20 REC-20 - Reject

Assessment field	Recorded conclusion
Recommendation	Standardize organization handling on NATALYX_ORG_ID.
Supporting evidence	#124 restores a configured organization constant, but the intended product is multi-resource/multi-tenant and Wave 2 reviewers/readers are insufficiently org-scoped.
Prior plan treatment	Organization scope is part of case/workspace contracts and RLS.
Assumptions	A fixed organization may remain a synthetic/dev bootstrap default only.
Security, privacy and operational impact	Prevents a deployment constant becoming tenant/access authority.
Dependency and migration impact	P03-05 and P13-05 derive organization from verified identity/grant/resource context; config default permitted only in synthetic bootstrap.
Alternatives considered	Global configured org; identity claim; resource/grant-derived org context.
Rationale	Configuration unification is convenient evidence, not the final authorization model. Organization must be verified from the authenticated/granted resource context.

Assessment field	Recorded conclusion
Affected WPs / PRs / gates	WP03 P03-05; WP13 P13-05
Explicit decision required	No.

1.3.2.21 REC-21 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Land the GC at shared /case/home and remove a duplicate GC Node 0 home.
Supporting evidence	#122 has paired case lenses; #124 routes GC to case home after bearer redemption even though Node 0 should not yet create a case.
Prior plan treatment	Free workspace and paid case are separate but landing wording was not explicit.
Assumptions	The GC may join a free workspace before any promotion and later receive a paid-case invitation.
Security, privacy and operational impact	Avoids duplicate participant shells and prevents pre-promotion users from being shown a canonical-case fiction.
Dependency and migration impact	P03-02/P06 workspace lens before promotion; P03-03/P09-04 shared case home only after canonical paid-case grant; P12 cutover removes duplicates.
Alternatives considered	Always case home; duplicate GC Node 0 home; shared shell with resource-specific projection.
Rationale	Keep one shared participant shell pattern, but route by actual resource: free-workspace GC projection before promotion, case home only after paid-case access exists.
Affected WPs / PRs / gates	WP03; WP06; WP09; WP12
Explicit decision required	No.

1.3.2.22 REC-22 - Accept with modification

Assessment field	Recorded conclusion
Recommendation	Keep return_to, token-scoped landing, duplicate-home cleanup, symbol cleanup and refreshed DS assets from #124.
Supporting evidence	Corrected #122 validates internal return_to; #124 provides one-time token landing and presentation cleanup; canonical participant DS owns released assets/tokens.
Prior plan treatment	Most items were salvage candidates without precise ownership.
Assumptions	DS assets are ported from an approved release, not vendored ad hoc.
Security, privacy and operational impact	Preserves UX value and resume behavior without weakening redirect, token or repository boundaries.

Assessment field	Recorded conclusion
Dependency and migration impact	P03-01 return_to; P03-02 token landing; P11-03 DS release; P05-03/P12-02 selective UI cleanup.
Alternatives considered	Copy branch files; discard polish; selective port from approved contracts.
Rationale	Adopt the behavior and cleanup, but keep redirect validation, resource-specific landing and canonical DS release ownership.
Affected WPs / PRs / gates	WP03; WP05; WP11; WP12
Explicit decision required	No.

1.3.3 Preserved Wave 2 branch

Field	Finding
Branch / head	feat/byos-journey-wave-2 / 5b63e3a7c3643efcd5f3e74f422d095423b55f59
Corrected #122 base	e85382150853cf4774948c55b91e330e7e69617e
Commit chain	3a549baf - phase-1 cluster pages and initial metadata-only request flow; e40eebaa - transactional submission, private rows and canonical case anchoring; 5b63e3a7 - role/owner checks, atomic review audit, fail-closed dispatch and N+1 removal
Useful	Projection-driven phase-1 cluster presentation, exact route allowlisting, person-versus-case-side ownership intent, transactional submission/work-item and review/audit patterns, fail-closed item retention, approved Learn status selection and 36 focused tests.
Unsafe	Runtime ensure_column/index DDL; identity/participation/access conflation; caller-supplied role/lens authority; unguarded/global loaders; no RLS or staff capability; metadata readiness represented as an approvable empty document; restart purges case-anchored work items; stale work item can approve a resubmitted row; paused/done actions are not capability-gated.
Defect reproductions	Second init_db changed a canonical case-anchored reviewer item from present to absent because participant_id='' matched the orphan cleanup.; After v1 was resolved and v2 resubmitted on the same row, the stale v1 work item approved v2 because review CAS bound only document_id/state, not an immutable submission revision.
Validation	Controlled local run: 535 passed, 9 skipped in 12.471s; focused Wave 2 cluster suite 36/36. No branch check runs, PostgreSQL, browser/accessibility or visual evidence was present.
Destinations	P01-01, P02-03, P03-01, P03-03, P03-05, P09-01, P09-04, P09-06, P11-03, P11-04, P12-02, P13-05
Disposition	Preserve paused at the exact head; selectively port semantics/tests only after adaptation. Do not merge, cherry-pick, continue implementation or use its runtime schema directly.

1.4 Explicit PR sequence

Order	ID	Title	Repository	Dependencies	Gate	Local preparation	Merge readiness
1	P00-01	Approve programme baseline and extraction ledger	.github	None	Pre-A0	Ready for Alan review and joint acceptance; no new implementation	Blocked pending Alan review and joint programme acceptance

1.4.1 P00-01 - Approve programme baseline and extraction ledger

Field	Plan
Repository / base	`.github` (`main`)
Gate / size	Pre-A0 / Medium
Local preparation status	Ready for Alan review and joint acceptance; no new implementation
Merge readiness	Blocked pending Alan review and joint programme acceptance
Technical-decision owner	None; implement the settled founder constraints and approved contracts
Dependencies	P00-01 plan sign-off only
Blocking decisions/checkpoints	None beyond dependencies and plan approval
Source / salvage	All listed draft PRs and protected worktrees

1.4.1.1 Objective Land the reviewed planning package and extraction baseline only after Alan has reviewed the consolidated document and Luke has accepted the programme contract.

1.4.1.2 Scope

- Record sign-off, unresolved decisions, source SHAs, and reconciliation procedure
- Freeze programme IDs used across the review package and future tracker

1.4.1.3 Explicit non-goals

- No implementation code
- No assignment becomes mandatory before Alan sign-off

1.4.1.4 Expected files or modules

- `natalyx-repair-program/*.md`
- `natalyx-repair-program/consolidated-plan.pdf`

1.4.1.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Repository-neutral planning and programme-control documents only.

1.4.1.6 Tests and validation Objective tests:

- git diff –check
- document/package parity validator
- PDF visual QA

Local validation:

- `git diff --check`
- `python scripts/validate_programme.py`

Cloud validation: run only through Gate **Pre-A0** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.1.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.1.8 Rollout Merge only after document/sign-off checks; it changes no runtime. Regenerate the Drive review package from the same canonical data; reactivate tracking only after approval.

1.4.1.9 Rollback or forward repair Correct the canonical data and regenerate; do not rewrite implementation history.

1.4.1.10 Dependencies and parallel work Hard dependencies: approved programme baseline. Parallel opportunities: None inside this package beyond review/test preparation.

1.4.1.11 Objective acceptance criteria

- ☐ Land the reviewed planning package and extraction baseline only after Alan has reviewed the consolidated document and Luke has accepted the programme contract.

- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ The planning record has matching dependency, local-preparation, merge-readiness, ownership, gate and disposition fields.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.1.12 Ownership and review

Role	Recommendation
Work-package DRI	Luke
Primary implementer	Luke (proposed; pending Alan review)
Technical-decision owner	None; implement the settled founder constraints and approved contracts
Reviewer	Alan
Final approver	Luke
PR-level ownership exception	None
Required expertise	programme architecture, technical programme management
Higher-capability review	Risk-proportionate; not mandatory by programme default

1.5 Cross-repository coordination

Repository	Authority after merge
`.github`	programme/governance evidence and future approved tracking

Merge order inside this package: `P00-01`.

Handoff rule: producer contract/version must merge and be pinned before its consumer enables the feature. During a partial merge, consumers fail closed or retain the last approved version; they do not fabricate data or silently broaden access.

Compatibility window: keep prior readers/writers and rollback image usable through the named gate; contract/migration PRs document the exact removal point.

1.6 Test and acceptance matrix

Test dimension	Method	Objective result
Happy path	SHA and timestamp reproducibility; Drive package/document identifier parity; No dirty-worktree mutation; HTTP and workflow evidence captured separately	Expected state/event/UI and named evidence are produced once.

Test dimension	Method	Objective result
Authorization failure	Wrong/no subject, role, membership, purpose or consent	403/404 as appropriate; no write or data leak; audit safe failure.
Role differences	Separate IP, GC, operator, provider/service identities	Only the approved lens/projection/actions appear.
Retries/duplicates	Repeat same canonical request/event	Original result returned; no duplicate membership/case/invoice/document/event.
Concurrency	Two writers/claimants/migrators/workers	One valid transition; loser receives deterministic stale/conflict response.
Stale state	Old revision/config/terms/token/artifact	Fail closed or approved compatibility behavior; never silent coercion.
Malformed input	Boundary, encoding, size, enum, redirect and identifier corpus	Validation before side effects; safe error.
Unavailable dependency	Database, intelligence, processor, S3/scanner or auth unavailable	Explicit degraded/blocked behavior; no hallucinated success.
Partial failure	Crash between external effect, DB transaction and outbox	Retry/forward repair converges from durable evidence.
Logout/login/resume	Session expires/restarts mid-flow	Return to authorized current state; no query/link authority.
Mobile/accessibility	320/375/768 widths, keyboard, focus, reduced motion	Core task completes with truthful state and no clipped controls.
Synthetic cloud	Known dev revision and synthetic identities/data	Gate artifact records SHA, dependency status, audit and cleanup.
Audit/observability	Inspect events/metrics/logs	Versions, actor/authority, correlation and reason present; no sensitive payload.

1.7 Risks and decisions

Founder outcomes, Alan's remaining technical ownership and external activation dependencies are recorded separately so a final policy is never mistaken for an active control.

ID	Status	Classification	Remaining owner	Affected / latest	Programme effect

Implementation risk	Owner	Treatment
Review findings arrive after decomposition	Luke	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
A protected worktree contains the only copy of useful code	Luke	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.
A green PR is mistaken for live readiness	Luke	Mitigate through explicit tests, rollout and forward-repair evidence before the associated gate.

1.8 Existing-work salvage

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
app#112	9605d88e31bd	Source-first 81-node/12-cluster surface map, participant-renderer boundaries, wave plan and cross-repo seams.	P00-01	Selective port, then supersede after extraction	Catalogued; content remains to be reconciled into replacement PR acceptance tests.
app#119	a8cd2f428535	Concise product-leverage framing and boundaries for the MVP flow.	P00-01	Retain as source or merge separately after plan decision	Catalogued; reconcile terminology into approved programme.
feat/byos-journey-wave-2	5b63e3a7c364	Projection-driven phase-1 cluster presentation, exact route allowlisting, person-versus-case-side ownership intent, transactional submission/work-item and review/audit patterns, fail-closed item retention, approved Learn status selection and 36 focused tests.	P01-01, P02-03, P03-01, P03-03, P03-05, P09-01, P09-04, P09-06, P11-03, P11-04, P12-02, P13-05	Preserve paused at the exact head; selectively port semantics/tests only after adaptation. Do not merge, cherry-pick, continue implementation or use its runtime schema directly.	Paused exact-head evidence; no direct merge

Package source inventory:

- App PRs #112, #117, #119, #121, #122, #123, #124

- Design-system PRs #7 and #8
- Provider-exchange, Node 0 onboarding/quiz, Learn-rendering, and intelligence dirty worktrees

1.9 Ownership recommendation

Luke owns product/architecture acceptance and the closure decision. Alan's completed technical recommendations are recorded with independent dispositions; implementation ownership remains proposed until the amended package is jointly accepted.

PR	WP DRI	Primary implementer	Technical-decision owner	Reviewer	Final approver	Exception
P00-01	Luke	Luke (proposed)	None; implement the settled founder constraints and approved contracts	Alan	Luke	None

PR ownership inherits the proposed work-package split pending Alan's review. Named technical-decision ownership remains separate and never transfers implementation ownership across work packages; reciprocal and external review requirements remain intact.

1.10 Definition of done

- ☐ Every proposed PR is merged in dependency order or explicitly dispositioned, with its objective acceptance criteria and review record complete.
- ☐ All package blocking decisions are resolved by the named owner; no commercial/privacy/security value is guessed in code.
- ☐ Local, PostgreSQL, role/authorization, retry/concurrency, failure, mobile and synthetic-cloud evidence required by this package is attached.
- ☐ Cross-repository contracts and artifact/migration versions are pinned; partial-merge behavior is fail-closed or explicitly degraded.
- ☐ Observability is sufficient to identify revision, transition, dependency and safe failure without sensitive payloads.
- ☐ Existing PR/worktree value and reviewer findings are extracted before closure; no cleanup occurs without team confirmation.
- ☐ The associated programme gate is accepted by Luke and any required external reviewer; tests/deploy alone do not establish B1/B2.